RECONFORGE — LOCAL-FIRST SECURITY PLATFORM

Complete Platform Operator & User Guide

An Easy-to-Read, Step-by-Step Manual for Bug Bounty Reconnaissance & Vulnerability Assessment

Platform: **FastAPI + SQLite + Single-Page Dashboard** Host: **127.0.0.1:8000 (Loopback Only)** Developer: **Anil Kashyap (anilkashyap01)** OS: **Kali Linux / Debian**

1. What Is ReconForge & How Does It Work?

ReconForge is a local command-and-control platform for security engineers, bug bounty researchers, and penetration testers. Instead of running 10 different CLI tools manually in separate terminal windows and juggling messy text output files, ReconForge connects and orchestrates industry-standard security scanners into a single, automated, web-based dashboard.

1 Define Scope

Add targets and boundaries. Out-of-scope exclusions are enforced at the backend engine to prevent unauthorized testing.

2 Execute Tools

Subfinder, dnsx, httpx, naabu, katana, and nuclei run safely with built-in token-bucket rate limiting.

3 Review & Export

Inspect live hosts, open ports, and potential findings. Export results to HTML, JSON, CSV, and logs.

> **The Golden Non-Negotiable Rule:** ReconForge *never* scans anything outside your authorized scope, *never* launches destructive/DoS attacks, *never* rotates IPs to evade limits, and stores all scan data and API credentials 100% locally on your machine in SQLite.

2. First Steps: Starting the App & Tool Health Matrix

To start ReconForge on your Kali Linux system, open your terminal and run:

```
python3 -m app
```

Open your web browser and navigate to: `http://127.0.0.1:8000`. ReconForge binds strictly to loopback (`127.0.0.1`) for safety.

Checking the Tool Health Matrix

In the top header, click **Settings & Tools** and navigate to the **Tool Health Matrix** tab. ReconForge inspects your Kali system `PATH` outside the virtualenv and verifies binary identity and versions:

TOOL NAME	SCANNER TYPE	STATUS	ROLE IN PIPELINE	INSTALLATION HINT (KALI LINUX)
Subfinder	Core Tool	Installed	Passive subdomain enumeration via OSINT sources	`sudo apt install subfinder`
dnsx	Core Tool	Installed	Fast DNS resolution, CNAME chains & IP extraction	`sudo apt install dnsx`
httpx	Core Tool	Installed	HTTP/HTTPS probing, status codes, server fingerprints	`sudo apt install httpx-toolkit`
Naabu	Core Tool	Installed	Fast, non-root TCP connect port scanner	`sudo apt install naabu`
Katana	Core Tool	Installed	Web application crawler & endpoint discovery	`sudo apt install katana`
Nuclei	Core Tool	Installed	Template-based vulnerability & misconfiguration checks	`sudo apt install nuclei`
Nmap	Optional	Installed	Detailed service versioning & OS detection	`sudo apt install nmap`
OWASP ZAP	Optional	Installed	Web application active security assessment	`sudo apt install zaproxy`
FFUF	Optional	Installed	Fast web fuzzer & directory discovery	`sudo apt install ffuf`
gau	Optional	Installed	Fetch URLs from AlienVault, Wayback, and CommonCrawl	`go install github.com/lc/gau/v2/cmd/gau@latest`
testssl.sh	Optional	Installed	TLS/SSL cipher suite & certificate security audit	`sudo snap install testssl`

3. Target Setup & Scope Management (The Safety Shield)

Bug bounty programs and legal engagements strictly forbid scanning out-of-scope assets. ReconForge enforces scope rules at the backend engine in `app/scope.py` before any tool is ever given an argument.

How to Add a Target

1. Click **+ Add Target** in the top navigation bar or Section A controls.
2. Enter a **Target Project Name** (e.g. `HackerOne - Shopify`).
3. In the **In-Scope Targets** box, list authorized domains, IPs, or CIDRs (one per line).
4. In the **Out-of-Scope Exclusions** box, list sensitive domains or third-party assets that must never be scanned.
5. Check the **Legal Authorization** checkbox and click **Create Target**.

Scope Rule Cheat Sheet

RULE SYNTAX	EXAMPLE	WHAT IT AUTHORIZES	WHAT IT BLOCKS (KEEPS YOU SAFE)
Exact Domain	`example.com`	Only `example.com`	Blocks `api.example.com`, `blog.example.com`
Wildcard Domain	`*.example.com`	All subdomains (`api.example.com`, `dev.example.com`)	Blocks apex `example.com`, blocks `fakeexample.com`
Both Together	`example.com` `*.example.com`	Apex AND all subdomains	Blocks all unrelated domains
Single IP	`192.168.1.50`	Only `192.168.1.50`	Blocks any other IP address
CIDR Subnet	`10.0.0.0/24`	All 254 hosts on `10.0.0.1` – `10.0.0.254`	Blocks IPs outside the `/24` boundary
Exclusion	`admin.example.com`	Overrides any in-scope rule	**NEVER CONTACTED:** Immediately pruned from all scanner queues

> **Pro Tip: Exclusions Always Win!** If your in-scope list has `*.example.com` and your exclusion list has `admin.example.com`, ReconForge will scan `api.example.com` but will never send a single packet to `admin.example.com`.

Testing Boundaries with the Interactive Scope Verifier

Under Section H (**Targets & Scope Management**), you will find the **Scope Boundary Verifier**. Type any hostname, IP, or full URL (e.g., `https://api.example.com/oauth`) and click **Test Boundary**. The backend returns authoritative verification:

✔ IN SCOPE
Matches authorized in-scope rule. Safe and approved for scanning.

✖ EXCLUDED
Matches an exclusion rule. Pruned and blocked from all scans.

⚠ NOT IN SCOPE
Unlisted or unauthorized. Dropped by backend validation.

4. Running Scans & Monitoring Real-Time Progress

Quick Passive Recon

Click **Start Recon** on any target. This executes purely non-intrusive discovery (Subfinder, gau, DNS resolution) with zero direct traffic to the target.

Full Scan Wizard

Click **Start Scan...** to open the Scan Wizard. Customize ports (top100, top1000, or custom), select scan profile, and configure Nuclei tags.

Scan Profiles Explained in Plain English

PROFILE	TOOLS USED	TARGET TRAFFIC?	BEST USED FOR
Passive Recon	Subfinder, gau, Shodan, urlscan	No Traffic	OSINT reconnaissance before testing begins; zero noise or alert triggers.
Standard Discovery	Subfinder, dnsx, httpx, Naabu	Active Probing	Resolving DNS, detecting live web servers (HTTP status codes), and safe TCP port checks.
Vulnerability Assessment	Standard + Nuclei	Active Scanning	Automated detection of security misconfigurations, exposed admin panels, and known CVEs.
Web Assessment	Standard + Katana + Nuclei	Deep Crawling	Crawling internal JavaScript endpoints, forms, and performing web vulnerability checks.

Monitoring Live Progress on the Dashboard

When a scan is launched, an **Active Scan Strip** appears at the top of your dashboard. You do not need to refresh the page:

- **Live Progress Percentage:** Updates every 2.5 seconds based on completed stages.
- **Current Stage Name:** Displays the tool actively executing (e.g. `Stage: httpx — probing live endpoints (40%)`).
- **Pause Button:** Pauses the pipeline cleanly between stages.
- **Cancel Button:** Immediately kills the active process group via `SIGTERM/SIGKILL`.
- **Scan Logs Tab:** Under Section F, watch timestamped console logs stream in live.

5. Reviewing Assets & Findings Like a Pro

Section C: Reconnaissance & Asset Inventory

Discovered assets are normalized into clean, searchable, filterable categories:

- **Subdomains:** All verified subdomains discovered by passive and active reconnaissance.
- **Live Hosts:** Responding web services showing HTTP status codes (200 OK, 301 Redirect, 404 Not Found), page titles, and web servers.
- **DNS Records:** A, CNAME, and TXT records mapped during DNS enumeration.
- **Open Ports:** TCP ports and services identified by Naabu connect scanning.
- **Exporting:** Click **Export CSV** to download the full asset inventory as a spreadsheet.

Section D: Vulnerabilities & Security Findings

Potential security weaknesses detected by scanners are organized by severity:

CRITICAL	HIGH	MEDIUM	LOW / INFO
RCE, SQLi, Auth Bypass	SSRF, XXE, Broken Access	XSS, CSRF, Misconfig	Info Disclosure, Headers

Clicking any finding row expands the **Finding Detail Panel**:

- **Ready-to-run curl reproduction command:** Click **Copy Curl** to reproduce the issue in your terminal.
- **Detection Evidence:** The exact HTTP request/response snippet that triggered the detection.
- **Remediation Roadmap:** Recommended security patches and linked CVE / OWASP advisories.
- **Analyst Triage Actions:** Mark finding as **Confirm Finding**, **Mark False Positive**, or **Mark Fixed**.

6. Exporting Reports & Security Deliverables

Under Section G (**Reports & Security Exports**), ReconForge provides 5 distinct export formats:

FORMAT	HOW TO ACCESS	USE CASE
Technical HTML Report	Click **Open HTML Report**	Complete, standalone security audit report rendered with autoescaped Jinja2 and strict CSP. Ready to print or share.
Executive Posture Summary	Click **Executive Summary**	High-level posture rating (Good, Moderate, High Risk), metrics breakdown, and one-click PDF print view for clients.
Machine-Readable JSON	Click **Download JSON**	Complete scan structure including tools, stages, DNS records, endpoints, and findings for SIEM / CI-CD ingestion.
Spreadsheet CSVs	Click **Export Findings CSV** or **Export Assets CSV**	Tabular spreadsheets suitable for importing into Microsoft Excel, Google Sheets, or bug bounty tracking boards.
Console Execution Logs	Click **Download All Logs**	Full timestamped log file (`reconforge-scan-X-logs.txt`) containing raw tool execution lines and stderr outputs.

7. Settings, Rate Limiting & Threat Intelligence

Open **Settings & Tools** from the top navigation bar:

- **Max Requests / Second (Default: 2.0 req/s):** Global rate limit across all tools using a token-bucket algorithm.
- **Per-Host Requests / Second (Default: 2.0 req/s):** Dedicated throttle per host to prevent triggering WAF rate limits or DoS.
- **Max Concurrent Jobs (Default: 1):** Conservative job queue preventing your Kali laptop CPU from spiking.
- **Scan Timeout (Default: 900s):** Hard timeout preventing hung tools from blocking subsequent stages.
- **Threat Intelligence:** Enter Shodan or urlscan API keys. Credentials are saved locally with `0600` permissions in `data/secrets.json` and are never leaked to scanners or reports.

> **ReconForge Platform Status:** Fully tested (113/113 automated tests passed), zero external attack code, 100% loopback compliant.